

DURCISSEMENT DU SYSTÈME PAR STRATÉGIES DE GROUPE (GPO)

L'implémentation des politiques de sécurité sur le contrôleur de domaine DC1 qui est celui de Genève répond aux exigences de durcissement de l'infrastructure du projet CYNA. L'objectif est de centraliser la configuration des postes et des sessions pour réduire la surface d'attaque logique et physique du domaine cyna.local.

Organisation de l'architecture GPO :

La gouvernance des stratégies est centralisée via la console de Gestion des stratégies de groupe. Pour éviter de polluer la Default Domain Policy, on crée un objet unique baptisé GPO_CYNA_SECURITE_GLOBALE qui est lié directement à la racine du domaine cyna.local.

Note d'architecture : Ce positionnement à la racine garantit que l'ensemble des règles de restriction s'appliquera par héritage descendant à toutes les Unités d'Organisation (OU) de l'entreprise, englobant nativement les futurs ordinateurs et utilisateurs du projet.

Spécifications techniques des 7 règles de durcissement

Voici le détail des sept règles implémentées dans l'objet de stratégie, présentées dans l'ordre de leur configuration :

- **Règle 1 : Durcissement de la politique des mots de passe**
 - Chemin : Configuration ordinateur > Stratégies > Paramètres Windows > Paramètres de sécurité > Stratégies de comptes > Stratégie de mot de passe
 - Paramètres : Longueur minimale du mot de passe fixée à 12 caractères / Exigences de complexité configurées sur Activé.
 - Justification sécurité : Cette configuration protège l'Active Directory contre les attaques par brute-force ou par dictionnaire sur les hashes de mots de passe.

- **Règle 2 : Gestion du cycle de vie des sessions locales (Verrouillage)**
 - Type : Configuration Utilisateur
 - Chemin : Configuration utilisateur > Stratégies > Modèles d'administration > Panneau de configuration > Personnalisation
 - Paramètres : Délai d'expiration de l'économiseur d'écran configuré sur 600 secondes (10 minutes) / Protéger l'économiseur d'écran par mot de passe positionné sur Activé.

- Justification sécurité : Prévient le risque d'usurpation d'identité en local. Si un collaborateur s'éloigne de son poste sans verrouiller sa session dans les bureaux de Genève, celle-ci s'isole automatiquement après 10 minutes d'inactivité et exige une réauthentification.

- Règle 3 : Neutralisation des vecteurs d'exfiltration physiques (USB)
 - Type : Configuration Ordinateur
 - Chemin : Configuration ordinateur > Stratégies > Modèles d'administration > Système > Accès au stockage amovible
 - Paramètre : Toutes les classes de stockage amovible : refuser tous les accès positionnés sur Activé.
 - Justification sécurité : Bloque nativement au niveau du noyau Windows l'utilisation de clés USB ou de disques externes non homologués. Cela élimine le risque de fuite de données et l'introduction de codes malveillants par voie physique.

- Règle 4 : Provisionnement du chiffrement BitLocker
 - Type : Configuration Ordinateur
 - Chemin : Configuration ordinateur > Stratégies > Modèles d'administration > Composants Windows > Chiffrement de lecteur BitLocker > Lecteurs du système d'exploitation
 - Paramètres : Exiger une authentification supplémentaire au démarrage positionné sur Activé / Option Autoriser BitLocker sans un TPM compatible explicitement cochée.
 - Justification sécurité : Prépare la sécurisation des données au repos. L'autorisation sans puce TPM matérielle est une contrainte technique indispensable pour valider et simuler cette brique de sécurité dans notre environnement de maquette virtualisée.

- Règle 5 : Restriction du CMD
 - Type : Configuration Utilisateur
 - Chemin : Configuration utilisateur > Stratégies > Modèles d'administration > Système
 - Paramètres : Empêcher l'accès à l'invite de commandes positionné sur Activé / Option Désactiver également le traitement des fichiers de commandes configurée sur Oui.
 - Justification sécurité : Réduit drastiquement les capacités d'un attaquant ou d'un utilisateur standard à faire de la reconnaissance réseau locale, tout en bloquant l'exécution de scripts automatisés malveillants (.bat, .cmd) en arrière-plan.

- Règle 6 : Verrouillage de l'Éditeur de Registre
 - Type : Configuration Utilisateur
 - Chemin : Configuration utilisateur > Stratégies > Modèles d'administration > Système
 - Paramètre : Empêcher l'accès aux outils de modification du Registre positionné sur Activé.
 - Justification sécurité : Bloque l'accès à regedit.exe pour les profils non privilégiés. Cela empêche toute altération arbitraire des clés système de l'OS et garantit le respect de la configuration décidée par les administrateurs.

- Règle 7 : Encadrement du déploiement applicatif
 - Type : Configuration Ordinateur
 - Chemin : Configuration ordinateur > Stratégies > Modèles d'administration > Composants Windows > Windows Installer
 - Paramètres : Désactiver Windows Installer positionné sur Activé / Menu déroulant réglé sur Uniquement pour les utilisateurs non gérés.
 - Justification sécurité : Interdit l'installation de packages tiers (.msi) par les collaborateurs standards afin de contrer le Shadow IT et l'exécution de logiciels potentiellement indésirables, tout en préservant les droits d'administration de l'équipe informatique.

Application et Validation Technique

Par défaut, l'Active Directory applique les nouvelles GPO de manière asynchrone selon un cycle de 90 à 120 minutes. Afin de valider immédiatement les configurations sur DC1 sans attendre, une actualisation synchrone forcée a été exécutée depuis l'invite de commandes d'administration : gpupdate /force

Génération du rapport d'audit de conformité

Afin d'apporter la preuve technique indiscutable de la bonne application de ces 7 règles pour le dossier de projet, un rapport de diagnostic a été généré au format HTML :

gpresult /h nomrapport.html